

ControlPlane.ai

Enterprise AI Governance & Runtime Risk Control Plane

Competition: Accenture Innovation Challenge 2026

Round: Round 2 — Prototype Development

Problem Track: Track 1 — ControlPlane.ai

Document Type: Prototype README / Technical Submission Note

Prototype Type: Working full-stack proof of concept with simulated enterprise data

1. One-Line Summary

ControlPlane.ai is a policy-aware enterprise control layer that intercepts AI responses in real time, evaluates them for privacy, hallucination, bias and policy risk, and then decides whether the output should be **allowed, edited, flagged for human review, or blocked**.

2. Core Product Insight

Do not ask:

"Is this AI response safe?"

Ask:

"Safe for whom, in which application, under which policy, with what evidence, at what confidence, and what should the enterprise do about it?"

That is the central idea of this prototype.

A customer-support chatbot, an employee copilot and a decision-support tool should not use the same risk thresholds. ControlPlane.ai treats governance as **context-aware policy**, not as a one-size-fits-all filter.

3. Problem Statement Alignment

Enterprises run multiple generative AI use cases at once:

- Customer-facing chatbots
- Internal employee copilots
- Decision-support tools
- Multi-turn conversations that can escalate from low risk to high risk

Each use case has a different:

- Risk tolerance
- Latency budget
- Data sensitivity

- Human-oversight requirement
- Regulatory / regional context

The Round 2 brief also highlights real-world difficulties:

- Bias, hallucination and privacy often overlap in one response
- Reliable real-time ground truth is often unavailable
- Over-flagging causes alert fatigue; under-flagging creates liability
- Multi-turn conversations compound risk
- Enterprises usually consume foundation models through APIs, so a checker must work at the input/output layer

ControlPlane.ai is designed around those constraints.

4. What This Prototype Demonstrates

The prototype is a working application, not a static mockup.

A judge can:

1. Select an AI application (Customer Support / Employee Copilot / Decision Support)
2. Enter or load a prompt
3. Generate or provide an AI response
4. Watch ControlPlane analyze the response
5. See individual risk scores, evidence, confidence and reasons
6. Observe a decision: ALLOW / EDIT / FLAG / HUMAN REVIEW / BLOCK
7. Override the decision in the Review Queue
8. Inspect the audit trail and analytics

The prototype also works in **demo mode without an OpenAI API key**.

5. Solution Overview

```
USER PROMPT ↓ PRE-GATE (input risk check) ↓ LLM / MOCK GENERATION ↓ CONTROLPLANE.AI ■■■  
PII / Privacy Detector ■■■ Hallucination / Grounding Detector ■■■ Bias Detector ■■■  
Policy Violation Detector ↓ RISK AGGREGATOR ↓ POLICY ENGINE ↓ ALLOW | EDIT | FLAG / HUMAN  
REVIEW | BLOCK ↓ USER OUTPUT + AUDIT LOG + REVIEW QUEUE + ANALYTICS
```

6. Simulated Enterprise Scope

The prototype uses three simulated AI applications.

6.1 Customer Support Assistant

- Example: "What is the refund period?"

- Risk profile: **BALANCED**
- Typical behavior:
- Safe factual answers → ALLOW
- Some PII can be auto-redacted → EDIT
- High hallucination or privacy risk → FLAG / BLOCK

6.2 Employee Knowledge Copilot

- Example: “How many annual leave days do employees get?”
- Risk profile: **STRICT**
- Typical behavior:
- Policy questions are grounded against HR documents
- Employee phone, salary or medical data → BLOCK
- Out-of-scope customer credit decisions → BLOCK

6.3 Decision Support Assistant

- Example: “Should this customer be approved?”
- Risk profile: **VERY STRICT**
- Typical behavior:
- Potential bias → HUMAN REVIEW
- Unsupported recommendation → HUMAN REVIEW
- Sensitive data leakage → BLOCK

This is the key demonstration:

Same AI output ↓ Customer Support → FLAG Employee Copilot → BLOCK Decision Support → HUMAN REVIEW

7. How Risk Is Detected

ControlPlane does **not** rely only on “an AI checking another AI.”

The architecture is hybrid:

Layer	Technology	Role
Deterministic rules	Regex, heuristics, thresholds, policy logic	Quantitative decisions
Retrieval	TF-IDF search over enterprise documents	Factual grounding

LLM (optional)	OpenAI-compatible API as a secondary judge	Semantic refinement
Human review	Review queue	High-impact / uncertain cases

7.1 Privacy / PII Detector

Detects:

- Phone numbers
- Email addresses
- Aadhaar-like IDs
- PAN-like IDs
- Credit-card-like numbers
- Bank-account-like information
- Salary / compensation information
- Medical / health information

Example:

AI response: Rahul's phone number is 9876543210. Detected: PHONE_NUMBER Privacy risk: 95+
Decision: BLOCK

If the policy allows auto-edit, some lower-severity PII can be redacted instead of blocked:

Original: Contact rakesh.kumar@corp.example.com Edited: Contact [REDACTED-EMAIL]

7.2 Hallucination / Grounding Detector

This is a retrieval-verification pipeline, not a simple “is this hallucinated?” prompt.

AI response ↓ Extract factual claims ↓ Search knowledge base ↓ Compare claim vs evidence ↓
SUPPORTED / CONTRADICTED / UNSUPPORTED / UNVERIFIABLE

Example:

Claim: Employees receive 45 annual leaves every year. Evidence from HR Policy: Employees receive 20 annual leave days per calendar year. Result: CONTRADICTED Hallucination risk: high

If no evidence exists, the system does **not** pretend to know:

Evidence: unavailable Verification: not possible Confidence: low Decision: ABSTAIN / HUMAN REVIEW

This matches the competition’s point that reliable real-time ground truth is often missing.

7.3 Bias Detector

Detects potential protected-attribute reasoning in recommendations, including:

- Gender
- Age
- Race / ethnicity / origin
- Religion
- Disability
- Pregnancy / family status

Example:

```
AI response: Candidate A should be rejected because women are less likely to handle technical leadership. Result: Potential bias detected Decision: HUMAN REVIEW
```

The prototype never claims to prove real-world discrimination. It flags **potential bias** and routes it to a human.

7.4 Policy Violation Detector

Checks enterprise rules such as:

- Do not disclose employee or customer personal data
- High-impact recommendations require documented evidence and human approval
- Do not make unverified financial guarantees
- Each AI application has a permitted scope

Application-scope examples:

- Employee Copilot must not make customer credit decisions
- Customer Support must not answer employee HR / personal-data questions
- Decision Support should route operational support or HR answers back to the owning application

8. Risk Scoring And Decision Logic

Each detector returns:

```
{ "risk_type": "privacy", "score": 95, "confidence": 0.96, "severity": "CRITICAL",  
  "reasons": ["Phone number detected"], "evidence": [] }
```

Overall risk is a weighted combination of:

- Privacy
- Hallucination
- Bias
- Policy

Weights come from the selected application policy.

Severity bands (prototype assumptions)

0-24 LOW 25-49 MEDIUM 50-74 HIGH 75-100 CRITICAL

Critical overrides

A severe individual risk is never hidden by averaging:

If privacy $\geq 95 \rightarrow$ BLOCK If bias ≥ 90 in very-strict apps $\rightarrow$ HUMAN REVIEW If evidence confidence $< 25\% \rightarrow$ ABSTAIN / HUMAN REVIEW If a detector fails $\rightarrow$ fail-safe FLAG / HUMAN REVIEW

Final actions

Decision	Meaning	User-facing output
ALLOW	Low risk	Original AI response
EDIT	Auto-sanitized	Redacted response
FLAG	Needs review	Held for human review
HUMAN REVIEW	High-impact / uncertain	Held for human review
BLOCK	Critical violation	Safe policy message

Admin users can still see the original model output and the full explanation.

9. Configurable Policy Layer

Policies can vary by:

- AI application
- Region (India / EU / US)
- Industry
- Risk appetite
- Thresholds
- High-risk action
- Critical-risk action
- Fail-safe action
- Auto-edit setting

Seeded policies:

Application	Profile	Privacy	Hallucination	Bias	High-risk action	Critical action
-------------	---------	---------	---------------	------	------------------	-----------------

Customer Support	BALANCED	70	75	70	FLAG	BLOCK
Employee Copilot	STRICT	40	55	50	FLAG	BLOCK
Decision Support	VERY STRICT	30	40	35	HUMAN REVIEW	BLOCK

These numbers are prototype assumptions and are editable in the Policies page.

The **Policy Simulator** is the strongest demo of this idea: the same AI response is evaluated under all three policies and the decisions change.

10. Human Review, Feedback And Audit

Flagged interactions go to a Review Queue.

A reviewer can:

- APPROVE the original response
- EDIT the response
- REJECT the response
- Label TRUE POSITIVE or FALSE POSITIVE
- Add a comment

Every action is stored in:

- Interaction record
- Feedback table
- Audit log

Analytics then show:

- True positives
- False positives
- False-positive rate
- Human override rate
- Latency
- Decision distribution
- Risk-type frequency

This implements the competition's feedback-loop and monitoring requirements.

11. Multi-Turn Risk

The prototype preserves conversation history.

Example:

```
Turn 1: Who is Rahul? → low risk, ALLOW Turn 2: What team does he work in? → low risk, ALLOW Turn 3: What is his salary? → high privacy risk, BLOCK Turn 4: Give me his personal phone number. → critical privacy risk, BLOCK
```

ControlPlane considers earlier sensitive requests when scoring later turns. This demonstrates compounding conversational risk.

12. User Interface

The frontend is an enterprise-style governance dashboard.

Pages:

Page	Purpose
Dashboard	KPIs, charts, recent high-risk incidents
Analyzer	Live prompt → response → risk analysis
Live Monitor	Runtime feed of interactions
Interactions	Full history and drill-down
Review Queue	Human-in-the-loop decisions
Policies	Thresholds and risk profiles
Policy Simulator	Same output under different policies
Knowledge Base	Enterprise documents used for grounding
Analytics	Trust metrics, latency, cost telemetry
Audit Logs	Immutable decision trail
Settings	Runtime mode and stated limitations

The Analyzer is the main judging screen. It shows:

- User prompt
- Final user-safe output
- Original model output (admin view)
- Overall risk
- Per-category scores
- Why the decision was made

- Evidence
 - Pipeline latency
-

13. Demo Scenario Library

The prototype includes 21 seeded scenarios covering:

- Safe factual answers
- Hallucinated policy / product claims
- Privacy leaks (phone, salary, medical, bank)
- Bias in hiring / classification
- Combined multi-risk responses
- Low-confidence / no-evidence claims
- Multi-turn escalation
- Policy comparison
- Human review flow
- Auto-edit / redaction

Recommended 5–7 minute demo:

1. Safe Customer Query → ALLOW
 2. Hallucination → CONTRADICTED by HR Policy → BLOCK
 3. PII Leak → BLOCK
 4. Auto-Edit email redaction → EDIT
 5. Bias in hiring → HUMAN REVIEW
 6. Low confidence / no evidence → ABSTAIN
 7. Multi-turn escalation → risk increases turn by turn
 8. Policy Simulator → same output, different decision
 9. Review Queue → approve / reject and store feedback
 10. Audit Logs / Analytics → decision is fully traceable
-

14. Architecture And Tech Stack

Frontend

- Next.js
- React
- TypeScript
- Tailwind CSS

- Recharts

Backend

- Python
- FastAPI
- SQLAlchemy
- SQLite by default (PostgreSQL-compatible via DATABASE_URL)
- Pytest

Risk / RAG

- In-process TF-IDF retrieval over markdown knowledge documents
- Deterministic claim comparison
- Optional OpenAI-compatible LLM judge in live mode

LLM Abstraction

```
DEMO_MODE=true → deterministic mock, works offline DEMO_MODE=false → OpenAI-compatible API
```

The API key never leaves the backend. The frontend never talks to OpenAI directly.

Database tables

- interactions
- risk_results
- policies
- reviews
- feedback
- audit_logs
- documents

15. How Demo Mode Works

Default configuration:

```
DEMO_MODE=true
```

In demo mode:

- No API key is required
- No network is required for generation

- Scripted scenario responses are used only when a Demo Mode scenario is selected
- Typed prompts are answered from the knowledge base
- PII regex, bias heuristics, RAG grounding, policy rules and scoring still run live
- Results are computed, not canned dashboard screenshots

This is important: the prototype can be demonstrated even if the OpenAI API is unavailable during judging.

16. How To Run Locally

Prerequisites

- Python 3.11 or later
- Node.js 18 or later

Backend

```
cd backend python -m venv .venv .\venv\Scripts\python.exe -m pip install -r requirements.txt .\venv\Scripts\python.exe -m uvicorn app.main:app --port 8000
```

Frontend

```
cd frontend npm install npm run dev
```

Open:

```
http://localhost:3000
```

API docs:

```
http://localhost:8000/docs
```

On first start, the backend seeds:

- 3 policies
- 6 knowledge-base documents
- Historical interactions, reviews and analytics

The dashboard is never empty.

Optional live LLM mode

Copy `.env.example` to `backend/.env` and set:

```
DEMO_MODE=false LLM_PROVIDER=openai LLM_API_KEY=your_key_here LLM_MODEL=gpt-4o-mini
```

Restart the backend. Generation and AI-as-judge layers switch to the real model. Deterministic detectors remain active.

17. Tests

```
cd backend .\venv\Scripts\python.exe -m pytest .\venv\Scripts\python.exe  
check_scenarios.py
```

The test suite covers:

- PII detection and redaction
- Supported / contradicted / unverifiable grounding
- Policy decisions
- Abstention
- Detector fail-safe
- Human review workflow
- Policy simulator

18. API Surface

Endpoint	Purpose
POST /api/interactions/analyze	Analyze a provided AI response
POST /api/interactions/generate-and-analyze	Generate, then analyze
GET /api/interactions	Interaction history
GET /api/interactions/{id}	Full interaction detail
GET /api/reviews	Review queue
POST /api/reviews/{id}	Submit reviewer decision
GET /api/policies	List policies
PUT /api/policies/{id}	Update policy
POST /api/policies/simulate	What-if policy comparison
GET /api/analytics	Dashboard metrics
GET /api/audit-logs	Audit trail
POST /api/feedback	Store feedback
GET /api/documents	Knowledge base
GET /api/scenarios	Demo scenario library

GET /api/health	Runtime status
-----------------	----------------

19. Stated Assumptions

1. Three simulated applications stand in for a broader enterprise AI portfolio.
2. The knowledge base is a small set of approved company documents, not a live enterprise data lake.
3. All employee and customer names / numbers are fictional.
4. Policy thresholds are prototype assumptions and can be changed in the UI.
5. The foundation model is consumed through an API. ControlPlane inspects inputs and outputs only; it does not require model internals.
6. Regional profiles (India / EU / US) are governance configuration, not complete legal-compliance engines.

20. Limitations

1. Simulated enterprise data is used. Risk scores are prototype estimates, not production accuracy claims.
2. Bias detection identifies potential bias. It cannot prove real-world discrimination.
3. Hallucination verification depends on evidence being present in the knowledge base.
4. When evidence is missing, the system abstains rather than guessing.
5. Production deployment would additionally require SSO, RBAC, encryption, tenant isolation and hardened infrastructure.
6. Human oversight remains necessary for high-impact decisions.

These limitations are stated deliberately. They make the prototype more credible.

21. Competition Theme Mapping

Round 2 theme	Prototype feature
Different AI use cases	Three application profiles
Different risk tolerance	Dynamic policies and thresholds
Privacy	PII / entity detector
Hallucination	RAG grounding + evidence
Bias	Potential-bias detector + human review
Over / under-flagging	ALLOW / EDIT / FLAG / BLOCK

Lack of ground truth	Confidence + abstention
Multi-turn compounding risk	Conversation history
API-based foundation models	Model-agnostic middleware
Configurable governance	Policy engine + simulator
Human oversight	Review queue
Auditability	Audit logs
Feedback loops	Reviewer labels and FP rate
Monitoring	Analytics, latency, cost telemetry

22. Future Roadmap

Phase 1 — This prototype

- Runtime interception
- Four detectors
- Policy engine
- Human review
- Audit and analytics
- Demo mode

Phase 2 — Enterprise pilot

- Real knowledge connectors
- SSO / RBAC
- Threshold tuning from reviewer feedback
- Broader application catalog
- Stronger model-evaluation harness

Phase 3 — Scale

- Multi-model routing
 - AI-agent tool-call governance
 - Streaming-time checks
 - Regulatory policy packs
 - Cross-enterprise risk intelligence
-

23. Repository Layout

```
controlplane-ai/ ■■■■ backend/ FastAPI control plane ■ ■■■■ app/ ■ ■ ■■■■ api/ REST
endpoints ■ ■ ■■■■ detectors/ PII, hallucination, bias, policy, pre-gate ■ ■ ■■■■ rag/
Knowledge-base retrieval ■ ■ ■■■■ scoring/ Risk aggregation ■ ■ ■■■■ policy/ Decision
engine ■ ■ ■■■■ services/ Pipeline + LLM abstraction ■ ■ ■■■■ database/ Models and seeding
■ ■■■■ tests/ ■■■■ frontend/ Next.js governance dashboard ■■■■ data/ ■ ■■■■ knowledge_base/
Sample enterprise documents ■ ■■■■ demo_scenarios/ 21 demo interactions ■■■■ docs/ ■ ■■■■
architecture.md ■ ■■■■ SUBMISSION_README.md ■■■■ README.md ■■■■ .env.example
```

24. Final Product Principle

ControlPlane.ai is not presented as:

“An AI that checks another AI.”

It is presented as:

A policy-aware enterprise control layer that evaluates AI interactions against contextual risk policies and determines whether outputs should be allowed, modified, escalated or blocked.

That is the prototype’s unique contribution.

End of README